

UmbraMarket S.r.l.

Final Vulnerability Assessment & Penetration Test Report

TRAINING SAMPLE — CLIENT-FACING REPORT

Tutti i nomi, sistemi, persone, processi, dati ed evidenze sono fittizi e creati esclusivamente per il laboratorio didattico.

Le evidenze tecniche LAB sono tratte dall'ambiente locale autorizzato. Le evidenze HUMAN/PROCESS sono simulazioni controllate o tabletop esplicitamente indicate.

1. Document Control

Field	Value
Customer	UmbraMarket S.r.l.
Engagement	Pre-release Vulnerability Assessment & Penetration Test
Assessment Type	Grey-box / Limited Scope
Assessment Window	Tuesday 09:00–13:00
Report Version	1.0 Training Sample
Classification	Training / Confidential
Prepared For	UmbraMarket Management & IT
Environment	Local training environment only

Version History

Version	Status	Change
0.1	Draft	Initial technical findings
0.5	Review	Added attack-chain analysis and remediation
1.0	Final	Client-ready training report

2. Executive Summary

UmbraMarket requested a limited Vulnerability Assessment and Penetration Test focused on the security boundaries protecting customer data, administrative functions and selected organizational processes.

The engagement combined customer discovery, organizational attack-surface analysis, technical reconnaissance, review of automated vulnerability-assessment output and controlled manual validation.

The assessment confirmed two technical authorization weaknesses in the training application. The most significant issue allowed an authenticated customer account to access an order belonging to another customer. A second issue allowed a normal customer role to access an administrative statistics function.

The simulated organizational assessment also identified weaknesses in visitor handling, removable-media behavior and support identity verification. These findings were validated only through controlled training simulations and must not be interpreted as evidence of compromise of any real user or real environment.

One network-related hypothesis was also tested and did **not** lead to a finding: the guest network segmentation control successfully prevented the tested internal reachability scenario.

No destructive testing, brute force, persistence, denial of service, mass enumeration or real-world social engineering was performed.

The priority remediation actions are to enforce server-side authorization consistently, strengthen visitor and support identity-verification procedures, reinforce safe handling of unknown removable media and retain the effective guest-network segmentation control.

A focused retest is recommended after remediation.

3. Engagement Objectives

The engagement was designed to answer the following business and security questions.

Business Questions

1. Can an ordinary customer access information belonging to another customer?
2. Can a normal user invoke functionality intended for privileged roles?
3. Can information gathered from the organizational environment create a credible multi-step attack path?
4. Which controls effectively interrupt potential attack chains?
5. Which scanner findings represent real vulnerabilities and which do not?

Security Objectives

- map the technical and organizational attack surface;
- distinguish facts, assumptions and hypotheses;
- validate selected candidate findings;
- demonstrate the minimum impact required to prove a security boundary failure;
- identify root causes rather than symptoms;
- provide actionable remediation and retest criteria.

4. Scope

Technical Scope

Asset	Purpose	Status
127.0.0.1:5005	UmbraMarket Guided application and API	In Scope
127.0.0.1:8080	Admin staging service	In Scope
127.0.0.1:9090	File service	In Scope
127.0.0.1:3000	Juice Shop training service	Out of Scope
Other hosts / LAN / Internet	Any external infrastructure	Out of Scope

Organizational / Human / Process Scope

The engagement included **controlled simulation and tabletop analysis only** for:

- visitor handling;
- reception process;
- removable-media handling;
- support identity verification;
- information exposure through normal work routines;
- attack-chain modeling.

No real employee, supplier, visitor or external party was contacted or deceived.

Test Accounts

Two fictional customer accounts were provided:

- Alice — customer role;
- Bob — customer role.

A privileged admin credential was not supplied to the student team.

Passwords and active session values are omitted from the client report.

5. Rules of Engagement

The following activities were permitted:

- browser and DevTools analysis;
- curl;
- Nmap on explicitly authorized local ports;
- Burp Suite Community / OWASP ZAP;
- authenticated testing with supplied accounts;
- manual parameter modification;
- minimal reversible proof-of-concept testing;
- controlled simulation of selected human/process scenarios;

- tabletop continuation of attack chains.

The following were prohibited:

- brute force;
- denial of service;
- destructive modifications;
- persistence;
- large-scale enumeration;
- testing against real people;
- real social engineering;
- malicious removable media;
- unauthorized physical access;
- external systems;
- continuation after sufficient evidence had been obtained.

Stop Condition

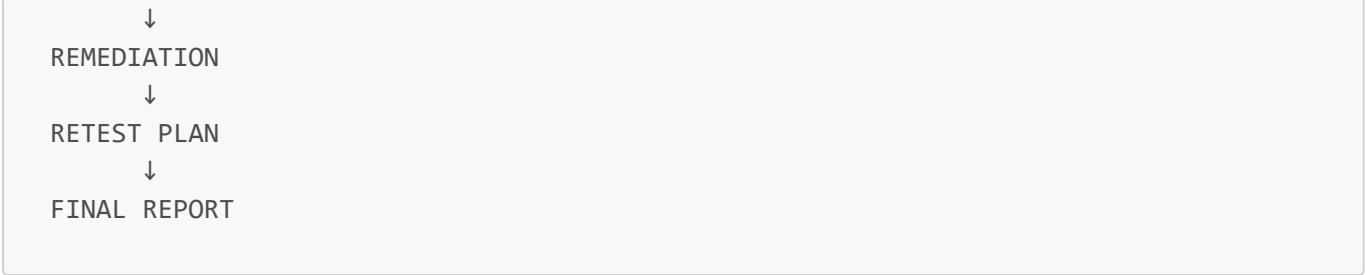
For each line of testing:

Stop when one controlled result is sufficient to demonstrate the security boundary failure being tested.

6. Methodology

The engagement followed the process below:

```
CUSTOMER DISCOVERY
  ↓
SCOPE VALIDATION
  ↓
ATTACK SURFACE MAPPING
  ↓
HYPOTHESIS GENERATION
  ↓
ATTACK CHAIN MODELING
  ↓
PRIORITIZATION
  ↓
TECHNICAL RECON
  ↓
VULNERABILITY ASSESSMENT
  ↓
MANUAL VALIDATION
  ↓
CONTROLLED PT
  ↓
EVIDENCE COLLECTION
  ↓
IMPACT ANALYSIS
```



Evidence Classification

Every evidence item was classified as one of the following:

Label	Meaning
LAB-VALIDATED	Directly validated in the local authorized technical environment
SIMULATED-CONTROLLED	Performed only as a harmless training simulation
TABLETOP	Assumed success used only to continue reasoning through an attack chain
CONTROL-EFFECTIVE	Test performed and defensive control prevented the hypothesized path
NOT-DEMONSTRATED	Insufficient evidence to report as a confirmed vulnerability

This classification is important because a client report must not present an assumption as a fact.

7. Limitations

The engagement had deliberate limitations.

The following were **not** performed:

- real-world physical intrusion;
- real social engineering;
- credential theft;
- malware deployment;
- weaponized removable media;
- persistence;
- lateral movement in a real enterprise network;
- denial of service;
- bulk data extraction;
- mass object enumeration;
- destructive changes;
- production-system testing.

The environment contains only fictional training data.

The simulated human/process findings demonstrate how the tested process behaved in the training scenario. They do not prove the same outcome for every employee, every day or every real production circumstance.

8. Attack Surface Summary

The discovery phase identified the following categories.

Surface	Examples Observed	Assessment Status
Technical	web app, API, staging, file service	Tested
Identity	customer roles, admin functions, sessions	Tested
Human	routine behavior, urgency, familiarity	Simulated / Tabletop
Physical	reception, visitor area, rear entrance	Simulated / Tabletop
Process	help desk, visitors, suppliers, offboarding	Partially simulated
Third Party	couriers, maintenance suppliers	Tabletop
Information	staging files, public roles, project names	Observed
Time	busy reception, breaks, meetings	Used in threat modeling

9. Attack Chain Summary

Legenda usata nelle chain:

```
[O] OBSERVED
[V] LAB-VALIDATED
[S] SIMULATED-CONTROLLED
[A] ASSUMED / TABLETOP
[N] NOT TESTED
[X] STOPPED / CONTROL EFFECTIVE
```

AC-01 — Customer Authorization Chain

```
[O] authenticated customer account
    ↓
[O] /api/orders/{id}
    ↓
[N] ownership validation may be missing
    ↓
[V] Alice requests Bob's known order
    ↓
[V] HTTP 200 + Bob order data
    ↓
[V] unauthorized cross-user access
```

Maximum demonstrated impact: access to one other customer's order.

Maximum hypothesized impact: additional order objects may be exposed if the same control failure applies elsewhere. This was not mass-tested.

AC-02 — Staging Information → Privileged Function

```
[O] Admin staging reachable
  ↓
[O] implementation details exposed
  ↓
[O] administrative API path identified
  ↓
[N] role enforcement may be missing
  ↓
[V] customer requests administrative statistics
  ↓
[V] HTTP 200
  ↓
[V] vertical authorization failure
```

Maximum demonstrated impact: customer role accessed administrative statistics.

No privileged modification was attempted.

AC-03 — Visitor Context → Process Trust

SIMULATED-CONTROLLED / TABLETOP

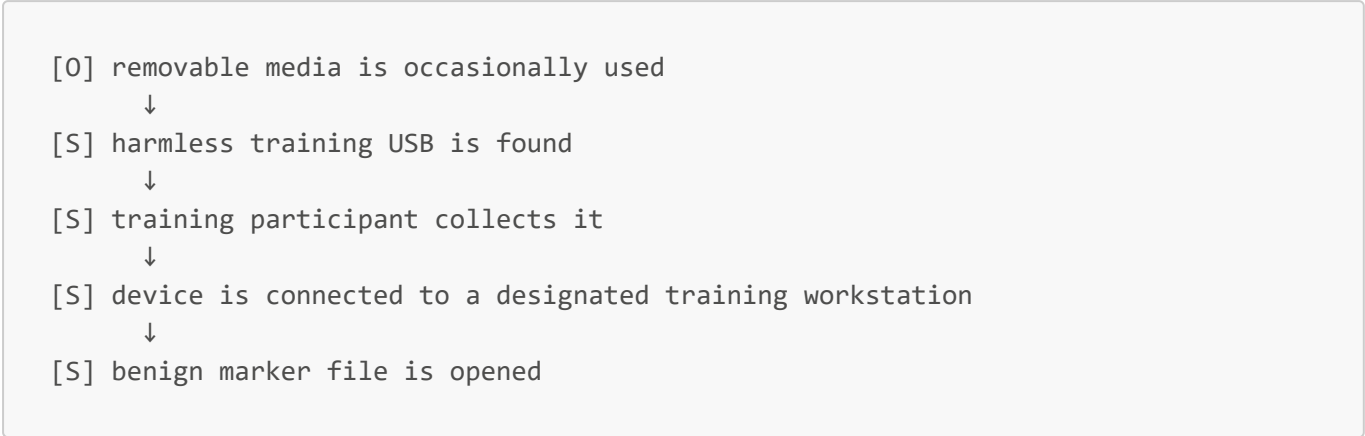
```
[O] reception handles visitors and known suppliers
  ↓
[A] staged visitor reaches visitor-accessible area
  ↓
[S] contextual information becomes visible
  ↓
[A] context is used in a support-process scenario
  ↓
[S] identity verification is insufficient in the simulation
  ↓
[S] training account recovery process proceeds further than intended
```

Maximum simulated impact: the training scenario demonstrated that contextual knowledge could increase the credibility of a request and that the simulated verification process did not require a sufficiently strong independent factor.

Not demonstrated: compromise of a real account, real employee deception or access to production systems.

AC-04 — Unknown Removable Media Handling

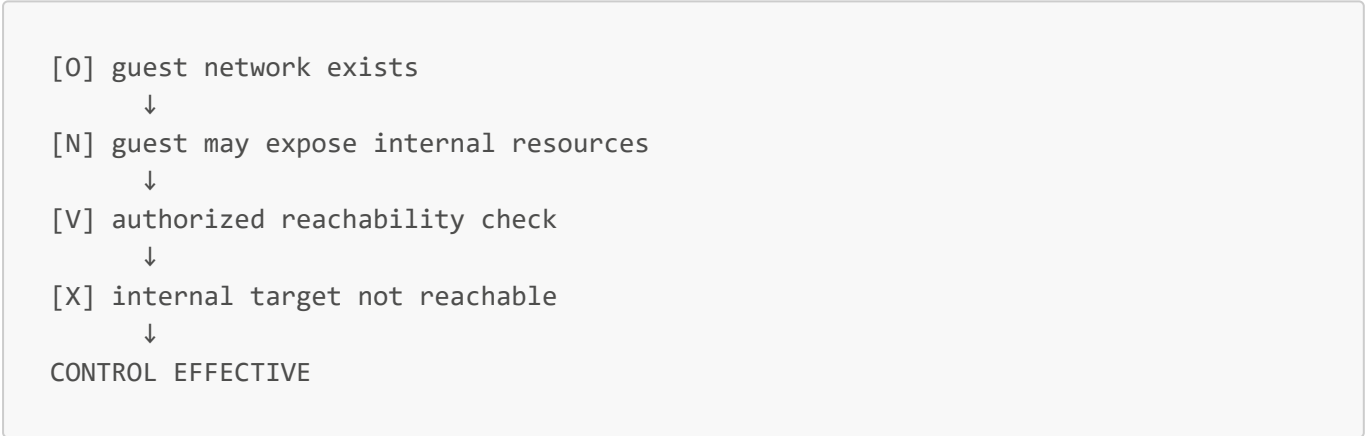
SIMULATED-CONTROLLED



No executable payload, macro, malware or exploit was used.

Maximum simulated impact: unsafe trust decision around an unknown removable device.

AC-05 — Guest Network Segmentation



This attack path was terminated by an effective control.

10. Findings Summary

ID	Finding	Area	Severity	Evidence Type	Status
F-01	Customer can access another customer's order	API Authorization	High	LAB-VALIDATED	Confirmed
F-02	Customer role can access administrative statistics	API Authorization	Medium	LAB-VALIDATED	Confirmed
F-03	Visitor-handling process can expose internal context	Physical / Process	Medium	SIMULATED-CONTROLLED	Confirmed in Simulation

ID	Finding	Area	Severity	Evidence Type	Status
F-04	Unknown removable media is trusted in training scenario	Human / Endpoint Process	Medium	SIMULATED-CONTROLLED	Confirmed in Simulation
F-05	Support identity verification is insufficient in simulated recovery flow	Identity / Process	High	SIMULATED-CONTROLLED	Confirmed in Simulation
O-01	Staging exposes implementation information	Information Disclosure	Low	LAB-VALIDATED	Observation
O-02	Guest segmentation prevented tested internal reachability	Network Control	Positive Control	CONTROL-EFFECTIVE	Effective
N-01	Scanner-reported possible server RCE	Technical	—	NOT-DEMONSTRATED	Not Confirmed

11. F-01 — Customer Can Access Another Customer's Order

Severity

High

Category

Broken Object Level Authorization / object-level access control.

Affected Asset

```
/api/orders/{id}
```

Business Rule

An ordinary customer must only be able to retrieve orders belonging to that customer.

Preconditions

- valid customer account;
- authenticated session;
- knowledge of another valid training order identifier.

Validation Performed

Step 1 — Establish Alice Baseline

Alice requested her own known order.

Evidence: **E-01**

Result:

```
HTTP 200
Alice's own order
```

Step 2 — Establish Bob Ownership

Bob requested his own known order.

Evidence: **E-02**

Result:

```
HTTP 200
Bob's order
```

Step 3 — Cross-User Validation

Using Alice's authenticated context, the test requested Bob's known order identifier.

Evidence: **E-03**

Expected Result

The application should deny access or behave as though the object is unavailable to Alice.

Expected examples:

```
HTTP 403
or
HTTP 404
```

with no protected order data.

Observed Result

```
HTTP 200
```

The response contained Bob's training order, including delivery information.

Evidence Correlation

```
E-01
proves Alice session can access Alice order

E-02
establishes ownership of order 1002 by Bob

E-03
shows Alice session receiving Bob's order
```

Demonstrated Impact

One authenticated customer can read order information belonging to another customer.

Not Demonstrated

The assessment did not demonstrate:

- all orders being accessible;
- automated enumeration;
- modification;
- deletion;
- account takeover;
- database compromise;
- server compromise.

Root Cause

The backend verifies authentication but does not enforce object ownership when retrieving the requested order.

Remediation

Enforce server-side object-level authorization on every request.

Conceptually:

```
requested order
+
authenticated identity
  ↓
ownership authorization
  ↓
ALLOW / DENY
```

Do not rely on:

- hidden identifiers;
- sequential-ID changes;
- UUIDs alone;
- UI restrictions.

Retest Procedure

1. authenticate as Alice;
2. verify Alice's own order remains accessible;
3. request Bob's training order;
4. verify denial;
5. confirm no Bob data appears in the response.

PASS

Cross-user request is denied and no protected data is returned.

FAIL

Any Bob order data is still returned to Alice.

12. F-02 — Customer Role Can Access Administrative Statistics

Severity

Medium

Category

Broken Function Level Authorization.

Affected Asset

```
/api/admin/stats
```

Expected Security Control

Only an authorized administrative role should invoke this function.

Validation

Using Alice's ordinary customer session:

```
GET /api/admin/stats
```

Evidence: **E-04**

Expected

```
DENY
```

Observed

```
HTTP 200
```

Administrative aggregate data was returned.

Demonstrated Impact

A customer role can access information exposed through an administrative function.

Not Demonstrated

No privileged write, account-management operation or administrative state change was attempted.

Root Cause

Authentication is enforced, but the required role/permission check is absent.

Remediation

Implement explicit server-side authorization for privileged functions.

Recommended verification logic:

```
authenticated?  
  ↓  
authorized role / permission?  
  ↓  
ALLOW / DENY
```

Retest

```
customer → /api/admin/stats → DENY
admin    → /api/admin/stats → ALLOW
```

13. F-03 — Visitor-Handling Process Exposes Internal Context

SIMULATED-CONTROLLED FINDING

Severity

Medium

Area

Physical / Visitor Process / Information Exposure.

Scenario

A controlled visitor simulation was used to evaluate what information could become available from a normal visitor-accessible area without crossing into restricted areas.

No unauthorized entry, bypass device or deception against a real employee was performed.

Evidence

H-01 — Visitor Area Observation Record

The simulation recorded that a staged visitor in the permitted visitor area could observe contextual information such as:

- meeting-room names;
- selected internal project references;
- supplier names;
- normal staff movement patterns;
- visitor-process behavior.

Expected Control

Visitor-accessible areas should expose only information appropriate for untrusted visitors.

Sensitive operational context should not be unnecessarily visible.

Observed Result

The training scenario exposed enough contextual information to materially improve later threat modeling and increase the plausibility of a separate process-based scenario.

Demonstrated Impact

The simulation demonstrated **information gain**, not system access.

Not Demonstrated

- unauthorized workstation access;
- credential theft;
- restricted-area access;
- network access;
- compromise of any real person.

Root Cause

The visitor process focuses primarily on physical admission but does not sufficiently consider passive information exposure in visitor-accessible areas.

Remediation

- review what operational information is visible from visitor-accessible locations;
- remove unnecessary project or internal process references;
- ensure visitors are appropriately accompanied where required;
- apply clean-board / clean-display practices to shared meeting areas;
- train reception and hosts to consider information exposure as part of visitor security.

Retest

Repeat the visitor-area review with a clean environment and verify that no internal project, supplier or operational details beyond business necessity are exposed.

14. F-04 — Unknown Removable Media Was Trusted in Controlled Simulation

SIMULATED-CONTROLLED FINDING

No malware, macro, exploit or executable content was used.

Severity

Medium

Area

Human / Endpoint Process / Removable Media.

Scenario

A harmless training USB device was used in a controlled classroom simulation.

The device contained only a benign text marker identifying it as part of the authorized exercise.

Evidence

H-02 — Removable Media Handling Record

The simulation showed the following sequence:

```
device discovered  
→ device collected  
→ device connected  
→ benign marker file opened
```

No harmful content was present.

Expected Behavior

An unknown removable device should be treated as untrusted and handled according to organizational policy, for example by reporting or transferring it to an approved technical process without directly using it on a normal endpoint.

Observed Result

The simulated participant trusted the unknown device sufficiently to connect it to the designated training workstation.

Demonstrated Impact

The exercise demonstrated a **trust and handling weakness** around unknown removable media.

It did not demonstrate malware execution or endpoint compromise.

Root Cause

The policy exists conceptually, but the behavioral decision in the simulation did not consistently follow the safer handling path.

Remediation

- reinforce removable-media awareness with scenario-based training;
- provide a clear "found device" procedure;
- make escalation to IT simple;
- consider technical restrictions on removable-media usage where business requirements allow;
- monitor removable-media events where appropriate.

Retest

Repeat a benign simulation after awareness and procedural changes.

PASS

Unknown media is not connected to a normal workstation and is handled through the approved process.

FAIL

Unknown media is again trusted and connected without verification.

15. F-05 — Support Identity Verification Is Insufficient in Simulated Recovery Flow

SIMULATED-CONTROLLED FINDING

No real employee was contacted and no production account was reset.

Severity

High

Area

Identity / Help Desk / Recovery Process.

Scenario

A role-play exercise tested whether contextual information about the organization could be enough to progress through a simulated account-recovery interaction.

The exercise intentionally did not use real credentials, real personal information or a real account.

Evidence

H-03 — Support Verification Simulation Record

The staged request contained only information already present in the training discovery pack.

The simulated support process accepted contextual knowledge as sufficient to move the recovery process beyond the point intended by the security policy.

Expected Control

Account recovery should require a strong, independent method of verifying the user's identity.

Knowledge of:

- role;
- project;
- manager;
- supplier;
- internal terminology;

should not by itself be sufficient.

Observed Result

In the simulation, the process relied too heavily on contextual familiarity and insufficiently on an independent authentication factor.

Demonstrated Impact

The training simulation demonstrated that organizational context could influence an identity-verification process.

Not Demonstrated

- reset of any real account;
- access to production email;
- MFA bypass;
- compromise of a real employee;
- use of a real support channel.

Root Cause

The recovery process lacks a sufficiently explicit and mandatory independent identity-verification step.

Remediation

Define a consistent recovery process requiring strong verification independent of contextual knowledge.

Examples of appropriate control objectives include:

- verified recovery channel;
- identity confirmation through a pre-established factor;
- controlled manager/owner approval where appropriate;
- documented exceptions;
- logging and review of recovery operations.

Do not use familiarity or organizational knowledge as the primary verification factor.

Retest

Run an authorized role-play using only information discoverable from normal business context.

PASS

The recovery process stops until an approved independent verification factor is completed.

FAIL

Contextual knowledge alone still allows the recovery process to proceed to a security-sensitive state.

16. O-01 — Staging Service Exposes Implementation Information

Severity

Low / Observation

The staging service exposes information that assists attack-surface discovery.

Observed information included implementation and API context.

This exposure did not by itself constitute compromise, but it contributed to AC-02 by enabling identification of an administrative function.

Remediation

- remove obsolete backup or draft content;
 - restrict staging environments;
 - minimize unnecessary implementation metadata;
 - review whether staging must be reachable by the intended user population.
-

17. O-02 — Guest Network Segmentation Control Was Effective

Status

CONTROL-EFFECTIVE

A test was performed to validate whether the guest-network scenario could reach the selected internal training resource.

The tested internal path was not reachable.

Result

```
guest network  
→ internal target  
→ blocked / unreachable
```

Interpretation

The tested segmentation control successfully interrupted that attack path.

Recommendation

Retain the current segmentation intent and include it in periodic configuration review and regression testing.

A positive security control should be preserved, not “fixed”.

18. N-01 — Scanner-Reported Possible Remote Code Execution

Status

NOT DEMONSTRATED

The automated scanner reported a possible remote-code-execution condition based primarily on web-server version fingerprinting.

Manual review did not demonstrate:

- confirmed vulnerable build;
- required configuration;
- vulnerable feature;
- exploit primitive;
- code execution;
- impact.

Therefore the alert was not promoted to a confirmed finding.

Teaching Point

scanner alert
≠
validated vulnerability

A client report must be based on evidence, not severity labels copied from tools.

19. Evidence Register

ID	Evidence	Type	Supports
E-01	Alice own-order baseline	LAB-VALIDATED	F-01
E-02	Bob own-order baseline	LAB-VALIDATED	F-01
E-03	Alice reads Bob order	LAB-VALIDATED	F-01
E-04	Customer reads admin stats	LAB-VALIDATED	F-02
H-01	Visitor-area observation record	SIMULATED-CONTROLLED	F-03

ID	Evidence	Type	Supports
H-02	Benign removable-media handling record	SIMULATED-CONTROLLED	F-04
H-03	Support identity-verification role-play	SIMULATED-CONTROLLED	F-05
C-01	Guest segmentation result	CONTROL-EFFECTIVE	O-02
N-01	Scanner RCE review notes	NOT-DEMONSTRATED	Non-Finding

20. Evidence Quality Rules Applied

The evidence pack was designed to be:

- minimal;
- relevant;
- reproducible;
- clearly labeled;
- tied to one or more conclusions;
- free from unnecessary secrets.

For each confirmed finding the report answers:

WHAT DID WE TEST?
WHAT SHOULD HAVE HAPPENED?
WHAT ACTUALLY HAPPENED?
WHAT EVIDENCE SUPPORTS THAT?
WHAT DOES IT PROVE?
WHAT DOES IT NOT PROVE?

21. Remediation Roadmap

Priority	Action	Related Area
P1	Enforce server-side object ownership checks	F-01
P1	Add negative authorization tests for cross-user access	F-01
P1	Strengthen account-recovery identity verification	F-05
P2	Enforce role authorization on privileged API functions	F-02
P2	Add negative role tests for administrative endpoints	F-02
P2	Improve unknown removable-media handling process	F-04
P2	Reduce unnecessary visitor-area information exposure	F-03

Priority	Action	Related Area
P3	Restrict staging and remove unnecessary implementation artifacts	O-01
Maintain	Preserve guest-network segmentation and test periodically	O-02

22. Retest Plan

A retest should verify both remediation correctness and absence of regressions.

F-01 — Object Authorization

```
Alice → Alice order = ALLOW
Alice → Bob order   = DENY
Bob   → Bob order   = ALLOW
```

F-02 — Function Authorization

```
customer → admin function = DENY
admin    → admin function = ALLOW
```

F-03 — Visitor Information Exposure

Repeat the controlled visitor-area observation.

PASS if unnecessary internal project/process information is no longer visible from visitor-accessible locations.

F-04 — Removable Media

Repeat a benign found-device simulation.

PASS if the device is handled through the approved process without connection to a normal workstation.

F-05 — Recovery Verification

Repeat a controlled role-play using only contextual organizational information.

PASS if the workflow stops until independent identity verification succeeds.

O-02 — Guest Segmentation

Re-run the authorized reachability check.

PASS if the selected internal target remains unreachable from the guest context.

23. What the Assessment Demonstrated

The engagement demonstrated that:

- object-level authorization was missing in one order API flow;
 - function-level authorization was missing in one administrative API flow;
 - selected visitor-accessible information could improve organizational context in a simulated chain;
 - a benign unknown removable device was trusted in the controlled scenario;
 - a simulated recovery process relied too heavily on contextual information;
 - guest-network segmentation interrupted the tested path;
 - a scanner-reported RCE was not sufficiently supported to be reported as a vulnerability.
-

24. What the Assessment Did NOT Demonstrate

The engagement did **not** demonstrate:

- compromise of the entire environment;
- access to all customer records;
- production database compromise;
- malware execution;
- real credential theft;
- real employee deception;
- real account takeover;
- bypass of production MFA;
- persistence;
- domain compromise;
- access to external systems.

These statements are intentionally explicit to prevent overclaim.

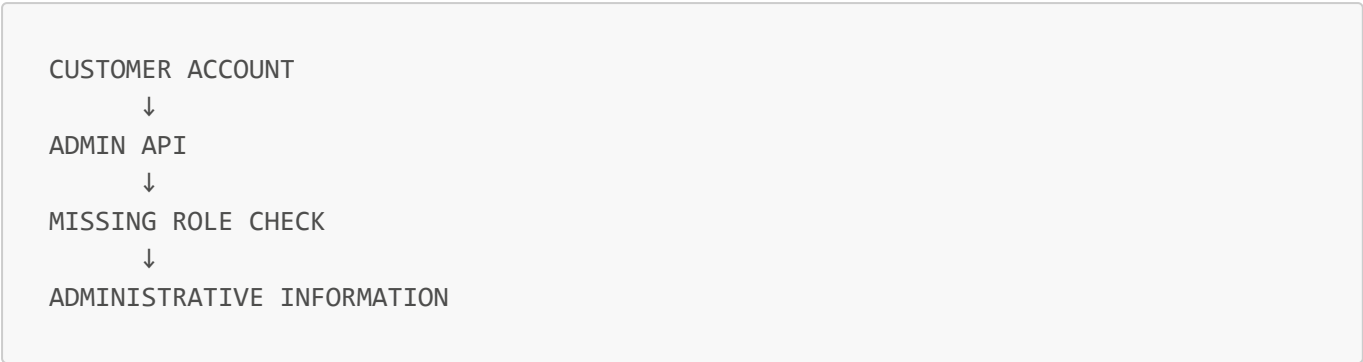
25. Client-Facing Attack Path View

A useful way to communicate the engagement is to show both confirmed and simulated paths.

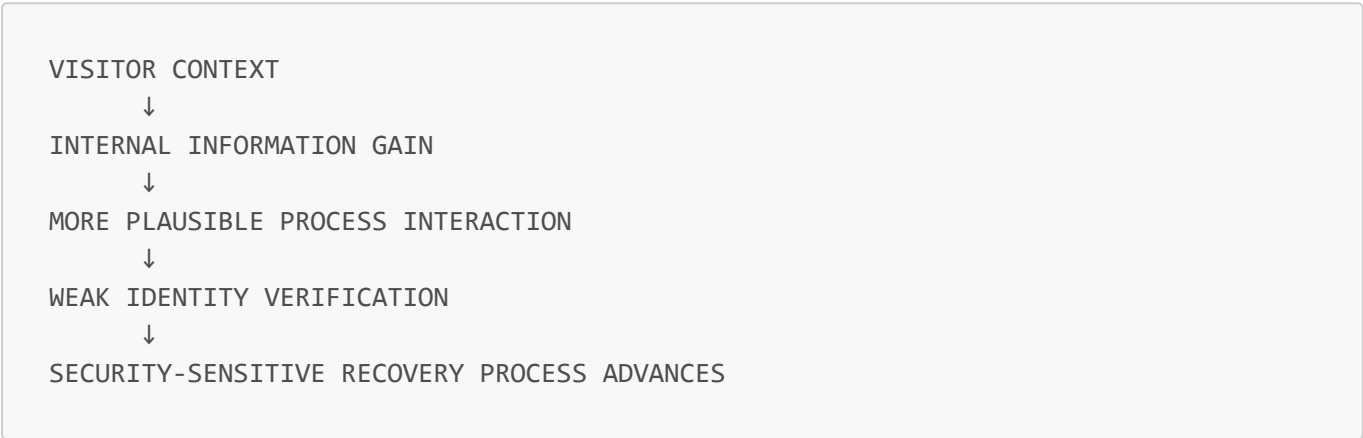
Confirmed Technical Path

```
CUSTOMER ACCOUNT
  ↓
ORDER API
  ↓
MISSING OWNERSHIP CHECK
  ↓
OTHER CUSTOMER ORDER
```

Confirmed Technical Path 2



Simulated Organizational Path



The third path is intentionally marked **simulated**.

26. Conclusion

The assessment identified security weaknesses across both technical authorization controls and selected organizational processes.

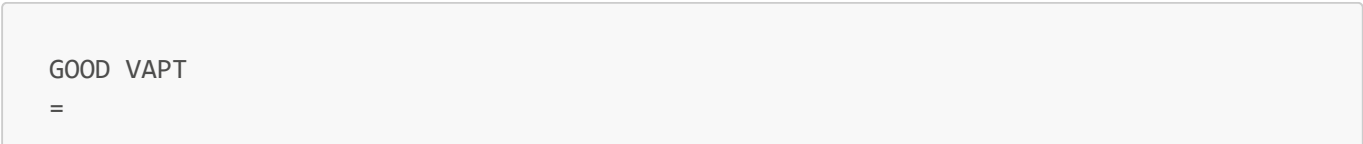
The most important technical issue was the failure to enforce object-level authorization on customer orders. This was directly validated with controlled evidence and should be remediated first.

A second confirmed technical issue showed insufficient role authorization on an administrative function.

The organizational simulation demonstrated that contextual information, visitor handling, removable-media decisions and identity-recovery procedures can interact to create attack opportunities even when no software exploit is involved.

At the same time, not every hypothesis succeeded. The tested guest-network path was stopped by effective segmentation, and the scanner-reported remote-code-execution condition was not confirmed.

This combination is important:



CONFIRMED FINDINGS
+
FAILED HYPOTHESES
+
EFFECTIVE CONTROLS
+
CLEAR LIMITATIONS
+
ACTIONABLE REMEDIATION

The recommended next step is to implement the remediation roadmap and perform a focused retest using the PASS/FAIL criteria defined in this report.

27. Teaching Note — How to Read This Report

When reviewing this report in class, do not focus only on the severity column.

For every finding ask:

1. WHAT WAS THE STARTING CONDITION?
2. WHAT WAS THE HYPOTHESIS?
3. WHAT CONTROL SHOULD HAVE STOPPED IT?
4. HOW WAS IT TESTED?
5. WHAT WAS EXPECTED?
6. WHAT WAS OBSERVED?
7. WHICH EVIDENCE PROVES IT?
8. WHAT IMPACT WAS ACTUALLY DEMONSTRATED?
9. WHAT WAS NOT DEMONSTRATED?
10. WHAT IS THE ROOT CAUSE?
11. HOW DO WE FIX IT?
12. HOW DO WE RETEST IT?

That is the difference between:

"I found something"

and:

"I can explain to the customer
what happened,
why it matters,
how I know,
how to fix it,
and how to verify the fix."